

INFORME DE CIBERSEGURIDAD

Plataforma ESERCOM - Gestion Integral Empresarial

Estado de controles, hallazgos, remediaciones y residual risk

Fecha del informe	31-07-2026 12:15
Alcance	App Node.js ESERCOM (API, auth, Angel IA, módulos, front)
Ambiente evaluado	Código local + producción esercom.cl
Clasificación	Confidencial — Uso interno
Versión	1.0

Este documento resume la postura de seguridad de ESERCOM tras la revisión técnica y las remediaciones aplicadas (julio 2026): autenticación, aislamiento multi-empresa, Angel IA / Cerebro, descargas, uploads, CORS, XSS y hardening operativo.

1. Resumen ejecutivo

ESERCOM es una aplicación Node.js multiempresa (Global, Sercom, Nexus, Táctica, Intercanje) con autenticación JWT, módulos operativos (materiales, flota, agenda, compras, etc.) y el asistente Angel IA con portal de entrenamiento (Cerebro). Se realizó una revisión orientada a riesgos explotables y se implementaron mitigaciones prioritarias en producción.

Veredicto

La postura actual es aceptable para operación tras los fixes de autenticación, descargas, XSS, rate limiting y hardening de arranque. Permanece un riesgo arquitectónico residual en modo MySQL compartido (BD única legado PHP), donde el selector de empresa no aísla filas entre marcas.

Tema	Detalle
Críticos / Altos mitigados	JWT obligatorio, admin estricto, reportes aislados, XSS, rate limit, checklist, agenda
Residual alto	MySQL multi-tenant cosmético (una BD para todas las marcas)
Residual medio	Tokens en localStorage, CORS configurable, Angel train clave compartida
Acción inmediata	Reiniciar Node; verificar JWT_SECRET / ADMIN / ANGEL_TRAIN passwords

2. Alcance de la revisión

- Autenticación y sesión (login, JWT, portales admin y Angel train).
- Autorización (roles, adminRequired, permisos de módulos, páginas).
- Aislamiento multi-empresa (SQLite vs MySQL).
- Angel IA: chat, reportes Excel, Cerebro (texto/imagen/Excel/Word/PDF), downloads.
- Uploads (checklist flota, conocimiento Angel).
- Front-end (XSS en shell, demo login, tokens en navegador).
- Hardening HTTP (CORS, headers, catch-all estático, límites de body).

3. Arquitectura y modelo de confianza

El front estático en public/ consume APIs bajo /api/* con Bearer JWT. El middleware authRequired valida el token, carga el usuario activo y fija req.db según empresa del JWT. El portal Angel train usa un scope JWT distinto (angel_train) rechazado en rutas de usuario normal.

Componente	Diseño	Implicancia
SQLite (local)	BD por empresa data/{slug}.db	Aislamiento fuerte
MySQL (prod)	Conexión compartida gosercom_productivo_db	Sin filtro empresa_id (legado PHP)
Reportes Excel	data/reportes/{empresa}/	Aislado + validación BD
Cerebro Angel	data/angel-conocimiento/{empresa}/	Archivos por empresa
Fotos checklist	data/uploads/checklist/{empresa}/ + API auth	No públicas en /uploads

4. Controles de seguridad implementados

4.1 Autenticación y secretos

Control	Estado	Detalle
JWT_SECRET	Mitigado	Prod exige ≥32 chars; falla boot si falta/ejemplo
ADMIN_PORTAL_PASSWORD	Mitigado	Obligatoria en prod; timing-safe
ANGEL_TRAIN_PASSWORD	Mitigado	Obligatoria en prod; /acceso-angel.html
ENCRYPTION_KEY	Parcial	Opcional; si no, deriva de JWT
Hashes PHP \$2y\$	Mitigado	Normalización a \$2a\$ en login
Rate limiting	Mitigado	Login 8/min; portales 5/min; recover 5/min
JWT Angel train TTL	Mitigado	2h / 8h (antes hasta 30d)
Demo en login	Mitigado	Eliminado hint admin@... / password

4.2 Autorización

Control	Estado	Detalle
adminRequired	Mitigado	Solo rol_id=1 o Administrador (no 'Administrativo')
paginas_permitidas	Mitigado	Fail-closed; vacío ≠ acceso total
Scope angel_train	OK	Rechazado en APIs de usuario
Agenda camión	Mitigado	Crear/editar/export requieren permiso
Checklist fotos	Mitigado	Subida con permiso; descarga autenticada

4.3 Angel IA y Cerebro

Control	Estado	Detalle
Descarga reportes	Mitigado	Carpeta por empresa + ownership/admin
Listado reportes	Mitigado	Propios / admin; emails JP ocultos
Sanitize reply	OK	Quita URLs inventadas; card Descargar
Cerebro multi-formato	OK	Texto, imagen, Excel, Word, PDF ≤12 MB
Mente ligera	OK	Chunks + ranking; no inyecta todo
Portal train	Parcial	Rate limit + TTL; clave maestra compartida

4.4 Hardening HTTP y front

Control	Estado	Detalle
Headers	OK	nosniff, SAMEORIGIN, Referrer-Policy, Permissions-Policy
CORS	Parcial	Allowlist CORS_ORIGINS; vacío = permisivo
Catch-all estático	Mitigado	Sin path traversal a .env
Body size	Mitigado	2 MB general; 14 MB solo uploads
XSS shell	Mitigado	escapeHtml nombre/empresa/subtítulo
Chat Angel	OK	textContent + escape en cards
/uploads/checklist	Mitigado	401 sin autenticación

5. Hallazgos (antes → después)

Tabla consolidada de hallazgos de la auditoría y su estado tras remediación.

Sev.	Hallazgo	Estado	Nota
Crítica	MySQL sin aislamiento entre empresas	Parcial	Requiere empresa_id o BD separadas
Alta	JWT_SECRET por defecto forjable	Mitigado	Fail-closed en producción
Alta	Download Excel cross-tenant / IDOR	Mitigado	Dir por empresa + BD
Alta	admin via includes('admin')	Mitigado	Criterio estricto
Alta	XSS nombre en shell	Mitigado	escapeHtml
Alta	Catch-all path traversal	Mitigado	Resolución segura
Alta	Sin rate limit auth/portales	Mitigado	Limiter por IP
Media	Fotos checklist públicas	Mitigado	data/ + API auth
Media	Agenda export/create sin permiso	Mitigado	Checks añadidos
Media	Angel train clave + JWT largo	Parcial	TTL corto; MFA pendiente
Media	paginas_permitidas falla abierto	Mitigado	Default []
Media	JSON 20 MB global DoS	Mitigado	Límite 2 MB
Baja	Demo credentials en login	Mitigado	UI removida

6. Superficies de ataque

6.1 Endpoints sensibles

Endpoint	Protección	Datos
POST /api/auth/login	Público + rate limit	Credenciales
POST /api/auth/acceso-sistema	Clave maestra + RL	Sesión admin
POST /api/auth/acceso-angel	Clave train + RL	Cerebro / OpenAI
GET .../reportes/download/:file	JWT + ownership	Excel operativos
POST .../conocimiento/docs/*	Token angel_train	Conocimiento
POST .../checklist/upload-foto	JWT + permiso	Fotos vehículos
GET .../agenda/reporte-excel	JWT + permiso	Rutas/precios

6.2 Datos sensibles

- Credenciales y hashes bcrypt (compatibilidad PHP).
- API keys OpenAI cifradas en BD (AES-256-GCM).
- Emails de jefes de proyecto en reportes Angel.
- Fotos de inspección vehicular y patentes.
- Documentos del Cerebro (procedimientos, catálogos, PDFs).

7. Riesgos residuales y backlog

Prioridad	Riesgo	Recomendación
Alta	MySQL multi-tenant	empresa_slug en tablas o BD por marca
Media	Token en localStorage	Cookie httpOnly + SameSite
Media	Angel train sin identidad	Admin real + MFA + auditoría
Media	CORS vacío permisivo	CORS_ORIGINS con esercom.cl
Media	Embeddings / RAG futuro	No mezclar docs entre empresas
Baja	Rate limit in-memory	Redis si hay multi-proceso
Baja	Catálogo G uploads	Mismo patrón que checklist

8. Requisitos operativos (producción)

Variable / acción	Requisito
JWT_SECRET	≥32 caracteres aleatorios (openssl rand -hex 32)
ADMIN_PORTAL_PASSWORD	Clave fuerte distinta del login de usuarios
ANGEL_TRAIN_PASSWORD	Clave fuerte; rotar periódicamente
ENCRYPTION_KEY	Recomendado (independiente del JWT)
NODE_ENV	production
CORS_ORIGINS	https://esercom.cl,https://www.esercom.cl
OPENAI_API_KEY	Solo en env; nunca en repositorio
Reinicio Node	Obligatorio tras desplegar cambios de seguridad

9. Matriz de cobertura por dominio

Dominio	Controles	Cobertura
Identidad y acceso	Login, JWT, portales, rate limit, admin	Cubierto
Autorización funcional	Flags, permisos, páginas fail-closed	Cubierto
Tenant SQLite	BD por empresa	Cubierto
Tenant MySQL	BD compartida legado	Parcial
Protección de archivos	Reportes, cerebro, checklist	Cubierto
IA / downloads	Sanitize, cards, ownership	Cubierto
XSS	Shell + chat	Cubierto
DoS / abuso API	Body limits + rate limit auth	Parcial
Secretos y crypto	Boot fail-closed + AES-GCM	Cubierto
Auditoría train	Sin identidad de entrenador	Parcial

10. Conclusiones

ESERCOM cuenta hoy con una base de controles alineada a buenas prácticas para una app empresarial en hosting compartido: secretos obligatorios, rate limiting en puertas de entrada, autorización más estricta, aislamiento de archivos sensibles y mitigación de XSS/traversal. El principal pendiente estratégico es el modelo multi-empresa en MySQL, heredado del PHP productivo: mientras todas las marcas compartan la misma base sin columna de tenant, el selector de empresa no debe interpretarse como aislamiento de seguridad.

Se recomienda mantener este informe como baseline, re-auditar tras cambios en Angel/Cerebro o auth, y planificar MFA + cookies httpOnly como siguiente oleada.

11. Anexos — Referencias de código

Tema	Archivos
Config / boot seguro	server/config.js, server/index.js
Auth / rate limit	server/routes/auth.js, server/middleware/rate-limit.js
Admin / sesión	server/middleware/admin.js, server/middleware/auth.js
Reportes Excel	server/services/angel-excel.js, server/routes/angel.js
Cerebro	server/services/angel-docs.js, server/routes/angel-train.js
Checklist fotos	server/services/checklist-flota.js
Front shell / login	public/js/auth.js, public/js/login.js, public/login.html

Documento generado automáticamente el 31-07-2026 a las 12:15. Clasificación: Confidencial. Destinatario: administración ESERCOM.